PHASE 3 — CISO/ISSO PROGRAM BUILD

Unified Control Library

Document Owner: Chief Information Security Officer / ISSO
Classification: Internal / Portfolio Reference
Version: 0.11 (Draft — 11 of 18 families)
Last Reviewed: 2026-10-27
Next Review Due: At Gate 3 sign-off, then annually and on any framework revision
Approved By: [Insert Approver / Title]

Table of Contents

(Updates automatically on open in Word. If blank, right-click and choose "Update Field.")

Document Control

Field	Value
Document ID	REF-08-001
Title	Unified Control Library
Document type	Control library (Phase 3 gating artifact)
Version	0.11
Status	Draft
Information classification	Internal
Owner	CISO
Approver	Gate 3 reviewers (CISO, control owners, Internal Audit)
Effective date	[MANAGEMENT DECISION REQUIRED] — on Gate 3 approval
Last review date	2026-10-27
Next review date	12 months after approval, or on any revision of a source framework
Review frequency	Annual; event-driven on framework or baseline change
Applies to	Reference Enterprise — all systems, data, workforce and third parties in the Phase 1 scope
Authoritative sources	NIST SP 800-53 Rev. 5 and SP 800-53B (Moderate); NIST CSF 2.0; ISO/IEC 27001:2022; CIS Controls v8.1; NIST SP 800-171 Rev. 3 (see Section 6)
Related controls and documents	REF-02-001 Applicability, Scoping & Framework Selection Register; REF-08-002 Assumptions & Decisions Log; control-library/VERIFICATION.md
Supersedes	None (first issue)

1. Purpose

This library is the single authoritative set of security controls for the Reference Enterprise. Every policy, standard, procedure, system security plan and assessment in later phases cites controls by the organization IDs defined here. Other frameworks map inward to this library; they never map to each other directly. That is what keeps one requirement from appearing three times with three different deadlines.

This document defines what each control requires and how it relates to other frameworks. It does not state that any control is implemented. The Reference Enterprise is greenfield: every control below is documented only, and each carries the marker that sends it to the POA&M until implementation evidence exists.

2. Scope

- Baseline: NIST SP 800-53B Moderate, base controls. This issue contains 113 controls in 11 of the 18 families that have Moderate-baseline controls.
- Families still being drafted: MA, MP, PE, PL, PS, SA, SR. They follow the same method and will be added in the next revision.

- Control enhancements selected by the Moderate baseline (for example IA-2(1), multi-factor authentication) are implemented as part of their base control. Their framework relationships are included in the base control's mappings.
- Program Management (PM) and PII Processing and Transparency (PT) are not part of the Moderate security baseline. PM is addressed by the CISO governance package (Phase 5); PT by the privacy overlay (Phase 7). [MANAGEMENT DECISION REQUIRED] — confirm at Gate 3.
- Overlays (PII, PHI, PCI, CUI) mark where a control carries additional obligations. Overlays add requirements; they never restate core controls (decision D-02).

3. Authority and Applicability

Phase 1 (REF-02-001, Section 3) selected NIST SP 800-53 Rev. 5 as the single authoritative control catalog, NIST CSF 2.0 as the outcome taxonomy, ISO/IEC 27001:2022 as the management-system structure, and CIS Controls as the baseline-tiering model. This library implements that decision. The federal track (SP 800-171 Rev. 3, CMMC, FedRAMP) remains an inactive overlay; its mappings are recorded so it can be activated without restructuring the library.

4. Control ID Convention and Record Structure

Organization IDs take the form ORG-<family>-<nnn>, where <nnn> is the 800-53 control number padded to three digits (AC-2 becomes ORG-AC-002). Keeping the number visible makes every record traceable to its source without a lookup table.

Record field	This issue	Completed in
ID, title, family, control requirement	Included	Phase 3
Framework mappings with source	Included (CSF 2.0, ISO 27001, CIS v8.1, 800-171 Rev. 3)	Phase 3
Overlays, evidence artifacts, owner role	Included	Phase 3
Organization-defined parameters	[ORGANIZATION INPUT REQUIRED]	Phase 4 standards
Control type, common/inherited/hybrid classification	[ORGANIZATION INPUT REQUIRED]	Phase 4 / Phase 6 SSP
Assessment procedures, frequency, pass/fail criteria	Not yet — derive from SP 800-53A	Phase 8
Metrics, KRIs, escalation rules	Not yet	Phase 8
Implementation status, POA&M reference, residual risk	Documented only; all to POA&M	Phase 6 onward

5. Roles and Responsibilities

Each control has one accountable owner role. Owners approve the control's organization-defined parameters, maintain its evidence, and answer assessor questions. The role list below is fixed for the program; a control may not be assigned to a role outside it.

Owner role	Controls owned
Security Operations Manager	13
Network Security Manager	12
CISO	10
Identity and Access Management Lead	10
Infrastructure Engineering Lead	10
IT Operations Manager	8
Application Security Lead	7
Cryptography and PKI Lead	6
Endpoint Engineering Manager	5
Data Governance Lead	5
GRC and Compliance Manager	5
Security Awareness and Training Lead	5
Security Architecture Lead	3
Risk Manager	3
Business Continuity Manager	3
Incident Response Lead	3
Change Manager	2
IT Asset Manager	2
Third-Party Risk Manager	1

6. Mapping Method and Sources

No mapping in this library rests on model or analyst recall. Each framework column comes from a published crosswalk, applied by a rerunnable build script (control-library/tools/build.py). Mappings express relationships, not equivalence: satisfying a mapped control does not by itself satisfy the other framework.

Framework	Source used	Basis	Verified
NIST SP 800-53 Rev. 5 / 800-53B	NIST OSCAL content: Rev. 5 catalog and Moderate baseline profile	Control list and official titles must match exactly	2026-10-27
NIST CSF 2.0	NIST CSF 2.0 Reference Tool export (informative references to SP 800-53 Rev. 5.1.1 / 5.2.0)	Subcategories NIST lists for the control or any of its enhancements	2026-10-27
ISO/IEC 27001:2022	NIST OLIR crosswalk, SP 800-53 Rev. 5 to ISO/IEC 27001:2022 (2023-10-12 update)	Annex A controls for the base control and its Moderate enhancements	2026-10-27
CIS Controls v8.1	CIS Controls v8.1 Mapping to NIST SP 800-53 Rev. 5 (CIS, July 2026)	Safeguards for the base control and its Moderate enhancements	2026-10-27

Framework	Source used	Basis	Verified
NIST SP 800-171 Rev. 3	NIST OSCAL content: SP 800-171 Rev. 3 catalog (97 active requirements)	Requirements whose source controls include this control	2026-10-27

6.1 Verification results

Draft control records were produced by the lab's AI agents and then checked against the sources above. The results show why the source-based step is required:

- CSF 2.0: 58 drafted links confirmed, 27 removed as unsupported, 318 added from NIST.
- ISO/IEC 27001:2022: 46 drafted links confirmed, 42 removed, 156 added from NIST's crosswalk.
- CIS v8.1: 59 drafted links confirmed, 27 removed, 163 added from CIS's mapping.
- SP 800-171 Rev. 3: 40 drafted citations confirmed; 1 incorrect citation removed.
- Records still resting on unsourced judgment: 0 of 113.

7. Library Summary

Family	Controls	Organization IDs
AC — Access Control	17	ORG-AC-001 … ORG-AC-022
AT — Awareness and Training	4	ORG-AT-001 … ORG-AT-004
AU — Audit and Accountability	11	ORG-AU-001 … ORG-AU-012
CA — Assessment, Authorization, and Monitoring	7	ORG-CA-001 … ORG-CA-009
CM — Configuration Management	12	ORG-CM-001 … ORG-CM-012
CP — Contingency Planning	9	ORG-CP-001 … ORG-CP-010
IA — Identification and Authentication	10	ORG-IA-001 … ORG-IA-012
IR — Incident Response	8	ORG-IR-001 … ORG-IR-008
RA — Risk Assessment	6	ORG-RA-001 … ORG-RA-009
SC — System and Communications Protection	18	ORG-SC-001 … ORG-SC-039
SI — System and Information Integrity	11	ORG-SI-001 … ORG-SI-016

8. Control Records

AC — Access Control

ORG-AC-001 Policy and Procedures

Field	Value
Organization control ID	ORG-AC-001
Authoritative source	NIST SP 800-53 Rev. 5 AC-1 Policy and Procedures (Moderate baseline)
Control requirement	The organization maintains an approved access control policy and supporting procedures, reviews them at least annually, and assigns an owner responsible for their upkeep and communication.
Overlays (additive)	PII, PHI, PCI, CUI
NIST CSF 2.0	GV.OC-03, GV.OV-01, GV.PO-01, GV.PO-02, GV.SC-03, ID.IM-01, ID.IM-02, ID.IM-03, PR.AA-01, PR.AA-05
ISO/IEC 27001:2022 Annex A	5.1, 5.2, 5.4, 5.15, 5.31, 5.36, 5.37
CIS Controls v8.1 Safeguards	6.1, 6.2
Federal track (inactive overlay)	SP 800-171 Rev. 3: 03.15.01 Policy and Procedures (NIST source mapping). SP 800-171 Rev. 3 does not carry a dedicated policy requirement for this family in the same form; confirm how policy is evidenced for CUI systems.
Evidence artifacts	Approved access control policy with version history, Annual policy review record
Control owner (role)	CISO
Organization-defined parameters	[ORGANIZATION INPUT REQUIRED] — set values for each 800-53 assignment/selection statement
Implementation status	Documented (draft). Not designed, implemented or evidenced. [CONTROL NOT IMPLEMENTED — ADD TO POA&M]

ORG-AC-002 Account Management

Field	Value
Organization control ID	ORG-AC-002
Authoritative source	NIST SP 800-53 Rev. 5 AC-2 Account Management (Moderate baseline)
Control requirement	Every account (user, privileged, service, shared, guest) has a documented owner and purpose, is approved before creation, is reviewed periodically, and is disabled promptly on role change, departure or inactivity.
Overlays (additive)	PII, PHI, PCI, CUI
NIST CSF 2.0	PR.AA-01, PR.AA-05, PR.DS-10, DE.CM-01, DE.CM-03
ISO/IEC 27001:2022 Annex A	5.16, 5.18, 8.2
CIS Controls v8.1 Safeguards	4.3, 5.1, 5.3, 5.5, 5.6, 6.1, 6.2, 6.7, 6.8, 12.5
Federal track (inactive overlay)	SP 800-171 Rev. 3: 03.01.01 Account Management (NIST source mapping). Related to SP 800-171 Rev. 3 requirement 03.01.01 (Account Management); confirm scope against CUI system boundary.

Field	Value
Evidence artifacts	Account inventory export from the identity provider, Quarterly access review sign-offs, Joiner/mover/leaver tickets with timestamps
Control owner (role)	Identity and Access Management Lead
Organization-defined parameters	[ORGANIZATION INPUT REQUIRED] — set values for each 800-53 assignment/selection statement
Implementation status	Documented (draft). Not designed, implemented or evidenced. [CONTROL NOT IMPLEMENTED — ADD TO POA&M]

ORG-AC-003 Access Enforcement

Field	Value
Organization control ID	ORG-AC-003
Authoritative source	NIST SP 800-53 Rev. 5 AC-3 Access Enforcement (Moderate baseline)
Control requirement	Systems enforce approved authorizations for access to information and functions, using role-based or attribute-based rules that default to deny.
Overlays (additive)	PII, PHI, PCI, CUI
NIST CSF 2.0	PR.AA-05, PR.DS-10, PR.IR-01
ISO/IEC 27001:2022 Annex A	5.15, 5.33, 8.3, 8.4, 8.18, 8.20, 8.26
CIS Controls v8.1 Safeguards	3.3, 6.7
Federal track (inactive overlay)	SP 800-171 Rev. 3: 03.01.02 Access Enforcement (NIST source mapping). Related to SP 800-171 Rev. 3 requirement 03.01.02 (Access Enforcement).
Evidence artifacts	Role-to-permission matrix, Access control list or policy configuration exports for key systems
Control owner (role)	Application Security Lead
Organization-defined parameters	[ORGANIZATION INPUT REQUIRED] — set values for each 800-53 assignment/selection statement
Implementation status	Documented (draft). Not designed, implemented or evidenced. [CONTROL NOT IMPLEMENTED — ADD TO POA&M]

ORG-AC-004 Information Flow Enforcement

Field	Value
Organization control ID	ORG-AC-004
Authoritative source	NIST SP 800-53 Rev. 5 AC-4 Information Flow Enforcement (Moderate baseline)
Control requirement	Approved flows of sensitive information between systems, network segments and external parties are defined and enforced through technical controls such as firewalls, gateways and data loss prevention rules.
Overlays (additive)	PII, PHI, PCI, CUI
NIST CSF 2.0	ID.AM-03, PR.DS-10, PR.IR-01, DE.CM-09
ISO/IEC 27001:2022 Annex A	5.14, 8.22, 8.23

Field	Value
CIS Controls v8.1 Safeguards	3.8
Federal track (inactive overlay)	SP 800-171 Rev. 3: 03.01.03 Information Flow Enforcement (NIST source mapping). Related to SP 800-171 Rev. 3 requirement 03.01.03 (Information Flow Enforcement); cross-domain needs require separate analysis.
Evidence artifacts	Network and data flow diagrams, Firewall or gateway rule set review records
Control owner (role)	Network Security Manager
Organization-defined parameters	[ORGANIZATION INPUT REQUIRED] — set values for each 800-53 assignment/selection statement
Implementation status	Documented (draft). Not designed, implemented or evidenced. [CONTROL NOT IMPLEMENTED — ADD TO POA&M]

ORG-AC-005 Separation of Duties

Field	Value
Organization control ID	ORG-AC-005
Authoritative source	NIST SP 800-53 Rev. 5 AC-5 Separation of Duties (Moderate baseline)
Control requirement	Duties that could enable fraud or undetected misuse, such as requesting and approving access or developing and releasing code, are assigned to different people and enforced by system roles.
Overlays (additive)	PCI, CUI
NIST CSF 2.0	PR.AA-05
ISO/IEC 27001:2022 Annex A	5.3
CIS Controls v8.1 Safeguards	3.3, 6.8
Federal track (inactive overlay)	SP 800-171 Rev. 3: 03.01.04 Separation of Duties (NIST source mapping). Related to SP 800-171 Rev. 3 requirement 03.01.04 (Separation of Duties).
Evidence artifacts	Documented separation-of-duties matrix, Role conflict report from the identity platform
Control owner (role)	Identity and Access Management Lead
Organization-defined parameters	[ORGANIZATION INPUT REQUIRED] — set values for each 800-53 assignment/selection statement
Implementation status	Documented (draft). Not designed, implemented or evidenced. [CONTROL NOT IMPLEMENTED — ADD TO POA&M]

ORG-AC-006 Least Privilege

Field	Value
Organization control ID	ORG-AC-006
Authoritative source	NIST SP 800-53 Rev. 5 AC-6 Least Privilege (Moderate baseline)
Control requirement	Users and processes receive only the access needed for their tasks. Administrative rights are separate from daily accounts, are time-bound where practical, and are reviewed regularly.

Field	Value
Overlays (additive)	PII, PHI, PCI, CUI
NIST CSF 2.0	PR.AA-05
ISO/IEC 27001:2022 Annex A	5.15, 8.2, 8.18
CIS Controls v8.1 Safeguards	3.3, 3.14, 5.4, 6.8
Federal track (inactive overlay)	SP 800-171 Rev. 3: 03.01.05 Least Privilege; 03.01.06 Least Privilege – Privileged Accounts; 03.01.07 Least Privilege – Privileged Functions (NIST source mapping). Related to SP 800-171 Rev. 3 requirements under 03.01.05 (Least Privilege) and its privileged account and function requirements; confirm exact IDs.
Evidence artifacts	Privileged account inventory with justifications, Privileged access review records, Privileged access management session logs
Control owner (role)	Identity and Access Management Lead
Organization-defined parameters	[ORGANIZATION INPUT REQUIRED] — set values for each 800-53 assignment/selection statement
Implementation status	Documented (draft). Not designed, implemented or evidenced. [CONTROL NOT IMPLEMENTED — ADD TO POA&M]

ORG-AC-007 Unsuccessful Logon Attempts

Field	Value
Organization control ID	ORG-AC-007
Authoritative source	NIST SP 800-53 Rev. 5 AC-7 Unsuccessful Logon Attempts (Moderate baseline)
Control requirement	Systems limit consecutive failed logon attempts and apply a lockout or delay, with alerting on repeated failures against sensitive accounts.
Overlays (additive)	PII, PHI, PCI, CUI
NIST CSF 2.0	PR.AA-03
ISO/IEC 27001:2022 Annex A	8.5
CIS Controls v8.1 Safeguards	4.1
Federal track (inactive overlay)	SP 800-171 Rev. 3: 03.01.08 Unsuccessful Logon Attempts (NIST source mapping). Related to SP 800-171 Rev. 3 requirement 03.01.08 (Unsuccessful Logon Attempts).
Evidence artifacts	Lockout threshold configuration screenshots or exports, Sample alerts for repeated failed logons
Control owner (role)	Identity and Access Management Lead
Organization-defined parameters	[ORGANIZATION INPUT REQUIRED] — set values for each 800-53 assignment/selection statement
Implementation status	Documented (draft). Not designed, implemented or evidenced. [CONTROL NOT IMPLEMENTED — ADD TO POA&M]

ORG-AC-008 System Use Notification

Field	Value
Organization control ID	ORG-AC-008
Authoritative source	NIST SP 800-53 Rev. 5 AC-8 System Use Notification (Moderate baseline)
Control requirement	Systems that process sensitive information display an approved notice before access stating authorized use, monitoring and consequences of misuse, and require acknowledgment where appropriate.
Overlays (additive)	CUI
NIST CSF 2.0	—
ISO/IEC 27001:2022 Annex A	8.5
CIS Controls v8.1 Safeguards	—
Federal track (inactive overlay)	SP 800-171 Rev. 3: 03.01.09 System Use Notification (NIST source mapping). Federal systems typically need legal-approved banner wording; confirm the corresponding SP 800-171 Rev. 3 requirement ID and any contractual wording.
Evidence artifacts	Approved banner text, Screenshots of the banner on representative systems
Control owner (role)	Security Operations Manager
Organization-defined parameters	[ORGANIZATION INPUT REQUIRED] — set values for each 800-53 assignment/selection statement
Implementation status	Documented (draft). Not designed, implemented or evidenced. [CONTROL NOT IMPLEMENTED — ADD TO POA&M]

No published source relationship: CSF 2.0, CIS v8.1. Map by judgment only if an assessor requires it. [ASSESSOR/AUDITOR VALIDATION REQUIRED]

ORG-AC-011 Device Lock

Field	Value
Organization control ID	ORG-AC-011
Authoritative source	NIST SP 800-53 Rev. 5 AC-11 Device Lock (Moderate baseline)
Control requirement	Endpoints and sessions lock automatically after a defined period of inactivity and require re-authentication to resume.
Overlays (additive)	PII, PHI, PCI, CUI
NIST CSF 2.0	—
ISO/IEC 27001:2022 Annex A	7.7, 8.1
CIS Controls v8.1 Safeguards	4.3
Federal track (inactive overlay)	SP 800-171 Rev. 3: 03.01.10 Device Lock (NIST source mapping). Related to SP 800-171 Rev. 3 requirement 03.01.10 (Device Lock).
Evidence artifacts	Endpoint management policy for screen lock timeout, Compliance report showing lock settings applied
Control owner (role)	Endpoint Engineering Manager
Organization-defined	[ORGANIZATION INPUT REQUIRED] — set values for each 800-53

Field	Value
parameters	assignment/selection statement
Implementation status	Documented (draft). Not designed, implemented or evidenced. [CONTROL NOT IMPLEMENTED — ADD TO POA&M]

No published source relationship: CSF 2.0. Map by judgment only if an assessor requires it. [ASSESSOR/AUDITOR VALIDATION REQUIRED]

ORG-AC-012 Session Termination

Field	Value
Organization control ID	ORG-AC-012
Authoritative source	NIST SP 800-53 Rev. 5 AC-12 Session Termination (Moderate baseline)
Control requirement	Sessions on applications and remote connections end automatically after defined inactivity or time limits, or on user logout.
Overlays (additive)	PII, PHI, PCI, CUI
NIST CSF 2.0	PR.AA-03
ISO/IEC 27001:2022 Annex A	—
CIS Controls v8.1 Safeguards	4.3
Federal track (inactive overlay)	SP 800-171 Rev. 3: 03.01.11 Session Termination (NIST source mapping). Related to SP 800-171 Rev. 3 requirement 03.01.11 (Session Termination).
Evidence artifacts	Application and VPN session timeout settings, Test record showing session expiry
Control owner (role)	Application Security Lead
Organization-defined parameters	[ORGANIZATION INPUT REQUIRED] — set values for each 800-53 assignment/selection statement
Implementation status	Documented (draft). Not designed, implemented or evidenced. [CONTROL NOT IMPLEMENTED — ADD TO POA&M]

No published source relationship: ISO 27001. Map by judgment only if an assessor requires it. [ASSESSOR/AUDITOR VALIDATION REQUIRED]

ORG-AC-014 Permitted Actions Without Identification or Authentication

Field	Value
Organization control ID	ORG-AC-014
Authoritative source	NIST SP 800-53 Rev. 5 AC-14 Permitted Actions Without Identification or Authentication (Moderate baseline)
Control requirement	Actions allowed without authentication, such as viewing public web content, are explicitly listed, approved and kept free of sensitive data.
Overlays (additive)	—
NIST CSF 2.0	PR.AA-01
ISO/IEC 27001:2022 Annex A	—
CIS Controls v8.1 Safeguards	—

Field	Value
Federal track (inactive overlay)	No SP 800-171 Rev. 3 requirement derives from this control (NIST). SP 800-171 Rev. 3 has no direct counterpart identified here; verify before asserting coverage.
Evidence artifacts	Approved list of unauthenticated actions and systems, Review record of public-facing services
Control owner (role)	Application Security Lead
Organization-defined parameters	[ORGANIZATION INPUT REQUIRED] — set values for each 800-53 assignment/selection statement
Implementation status	Documented (draft). Not designed, implemented or evidenced. [CONTROL NOT IMPLEMENTED — ADD TO POA&M]

No published source relationship: ISO 27001, CIS v8.1. Map by judgment only if an assessor requires it. [ASSESSOR/AUDITOR VALIDATION REQUIRED]

ORG-AC-017 Remote Access

Field	Value
Organization control ID	ORG-AC-017
Authoritative source	NIST SP 800-53 Rev. 5 AC-17 Remote Access (Moderate baseline)
Control requirement	Remote access methods are authorized, use encrypted channels and multi-factor authentication, are routed through managed access points, and are monitored.
Overlays (additive)	PII, PHI, PCI, CUI
NIST CSF 2.0	PR.AA-05
ISO/IEC 27001:2022 Annex A	5.14, 6.7, 8.16
CIS Controls v8.1 Safeguards	3.10, 12.7, 13.5
Federal track (inactive overlay)	SP 800-171 Rev. 3: 03.01.12 Remote Access (NIST source mapping). Related to SP 800-171 Rev. 3 requirement 03.01.12 (Remote Access); CUI traffic requires approved cryptography.
Evidence artifacts	Remote access standard, VPN or zero-trust gateway configuration showing MFA enforcement, Remote access log samples
Control owner (role)	Network Security Manager
Organization-defined parameters	[ORGANIZATION INPUT REQUIRED] — set values for each 800-53 assignment/selection statement
Implementation status	Documented (draft). Not designed, implemented or evidenced. [CONTROL NOT IMPLEMENTED — ADD TO POA&M]

ORG-AC-018 Wireless Access

Field	Value
Organization control ID	ORG-AC-018
Authoritative source	NIST SP 800-53 Rev. 5 AC-18 Wireless Access (Moderate baseline)
Control requirement	Wireless networks are authorized, use strong authentication and encryption, and are separated from sensitive internal segments. Rogue access points are

Field	Value
	detected.
Overlays (additive)	PCI, CUI
NIST CSF 2.0	PR.AA-05
ISO/IEC 27001:2022 Annex A	5.14, 8.20
CIS Controls v8.1 Safeguards	4.2, 12.6
Federal track (inactive overlay)	SP 800-171 Rev. 3: 03.01.16 Wireless Access (NIST source mapping). Related to SP 800-171 Rev. 3 requirement 03.01.16 (Wireless Access).
Evidence artifacts	Wireless configuration standard, Wireless controller settings export, Rogue access point scan results
Control owner (role)	Network Security Manager
Organization-defined parameters	[ORGANIZATION INPUT REQUIRED] — set values for each 800-53 assignment/selection statement
Implementation status	Documented (draft). Not designed, implemented or evidenced. [CONTROL NOT IMPLEMENTED — ADD TO POA&M]

ORG-AC-019 Access Control for Mobile Devices

Field	Value
Organization control ID	ORG-AC-019
Authoritative source	NIST SP 800-53 Rev. 5 AC-19 Access Control for Mobile Devices (Moderate baseline)
Control requirement	Mobile devices that access organizational data are enrolled in device management, encrypted, protected by a passcode, and can be locked or wiped when lost.
Overlays (additive)	PII, PHI, PCI, CUI
NIST CSF 2.0	PR.AA-05
ISO/IEC 27001:2022 Annex A	5.14, 7.9, 8.1
CIS Controls v8.1 Safeguards	4.1, 4.11, 4.12, 6.4
Federal track (inactive overlay)	SP 800-171 Rev. 3: 03.01.18 Access Control for Mobile Devices (NIST source mapping). Related to SP 800-171 Rev. 3 requirement 03.01.18 (Access Control for Mobile Devices).
Evidence artifacts	Mobile device management enrollment report, Mobile security configuration profile
Control owner (role)	Endpoint Engineering Manager
Organization-defined parameters	[ORGANIZATION INPUT REQUIRED] — set values for each 800-53 assignment/selection statement
Implementation status	Documented (draft). Not designed, implemented or evidenced. [CONTROL NOT IMPLEMENTED — ADD TO POA&M]

ORG-AC-020 Use of External Systems

Field	Value
Organization control ID	ORG-AC-020
Authoritative source	NIST SP 800-53 Rev. 5 AC-20 Use of External Systems (Moderate baseline)
Control requirement	Use of external systems, including personal devices and third-party platforms, to process or store organizational data is limited to approved cases with defined terms and technical restrictions.
Overlays (additive)	PII, PHI, PCI, CUI
NIST CSF 2.0	ID.AM-02, ID.AM-04
ISO/IEC 27001:2022 Annex A	5.14, 7.9, 8.20
CIS Controls v8.1 Safeguards	4.11, 15.3, 15.4, 15.6
Federal track (inactive overlay)	SP 800-171 Rev. 3: 03.01.20 Use of External Systems (NIST source mapping). Related to SP 800-171 Rev. 3 requirement 03.01.20 (Use of External Systems); CUI handling by external providers needs contractual flow-down review.
Evidence artifacts	External system use standard, Approved third-party and cloud service register, Conditional access policy for unmanaged devices
Control owner (role)	Third-Party Risk Manager
Organization-defined parameters	[ORGANIZATION INPUT REQUIRED] — set values for each 800-53 assignment/selection statement
Implementation status	Documented (draft). Not designed, implemented or evidenced. [CONTROL NOT IMPLEMENTED — ADD TO POA&M]

ORG-AC-021 Information Sharing

Field	Value
Organization control ID	ORG-AC-021
Authoritative source	NIST SP 800-53 Rev. 5 AC-21 Information Sharing (Moderate baseline)
Control requirement	Sharing of sensitive information with external parties requires a documented business need, an authorization decision by the information owner, and an approved sharing method.
Overlays (additive)	PII, PHI, CUI
NIST CSF 2.0	—
ISO/IEC 27001:2022 Annex A	—
CIS Controls v8.1 Safeguards	15.2
Federal track (inactive overlay)	No SP 800-171 Rev. 3 requirement derives from this control (NIST). CUI dissemination is governed by the applicable CUI category and marking rules; this is not a direct SP 800-171 Rev. 3 mapping.
Evidence artifacts	Information sharing procedure, Sample sharing approvals with data owner sign-off
Control owner (role)	Data Governance Lead

Field	Value
Organization-defined parameters	[ORGANIZATION INPUT REQUIRED] — set values for each 800-53 assignment/selection statement
Implementation status	Documented (draft). Not designed, implemented or evidenced. [CONTROL NOT IMPLEMENTED — ADD TO POA&M]

No published source relationship: CSF 2.0, ISO 27001. Map by judgment only if an assessor requires it. [ASSESSOR/AUDITOR VALIDATION REQUIRED]

ORG-AC-022 Publicly Accessible Content

Field	Value
Organization control ID	ORG-AC-022
Authoritative source	NIST SP 800-53 Rev. 5 AC-22 Publicly Accessible Content (Moderate baseline)
Control requirement	Only designated, trained personnel may post to public systems. Content is reviewed for non-public information before posting and checked periodically.
Overlays (additive)	PII, CUI
NIST CSF 2.0	—
ISO/IEC 27001:2022 Annex A	—
CIS Controls v8.1 Safeguards	14.5
Federal track (inactive overlay)	SP 800-171 Rev. 3: 03.01.22 Publicly Accessible Content (NIST source mapping). Related to SP 800-171 Rev. 3 requirement 03.01.22 (Publicly Accessible Content); confirm ID.
Evidence artifacts	Public content publication procedure, Authorized publisher list, Periodic public site review record
Control owner (role)	Data Governance Lead
Organization-defined parameters	[ORGANIZATION INPUT REQUIRED] — set values for each 800-53 assignment/selection statement
Implementation status	Documented (draft). Not designed, implemented or evidenced. [CONTROL NOT IMPLEMENTED — ADD TO POA&M]

No published source relationship: CSF 2.0, ISO 27001. Map by judgment only if an assessor requires it. [ASSESSOR/AUDITOR VALIDATION REQUIRED]

AT — Awareness and Training

ORG-AT-001 Policy and Procedures

Field	Value
Organization control ID	ORG-AT-001
Authoritative source	NIST SP 800-53 Rev. 5 AT-1 Policy and Procedures (Moderate baseline)
Control requirement	An approved security awareness and training policy and supporting procedures define scope, roles, responsibilities, management commitment and coordination. They are disseminated to relevant personnel, have a designated owner, are reviewed at an organization-defined frequency, and are updated after organization-defined events such as significant organizational, regulatory, threat

Field	Value
	records, Legal hold notices and hold release records
Control owner (role)	Data Governance Lead
Organization-defined parameters	[ORGANIZATION INPUT REQUIRED] — set values for each 800-53 assignment/selection statement
Implementation status	Documented (draft). Not designed, implemented or evidenced. [CONTROL NOT IMPLEMENTED — ADD TO POA&M]

No published source relationship: ISO 27001. Map by judgment only if an assessor requires it. [ASSESSOR/AUDITOR VALIDATION REQUIRED]

ORG-SI-016 Memory Protection

Field	Value
Organization control ID	ORG-SI-016
Authoritative source	NIST SP 800-53 Rev. 5 SI-16 Memory Protection (Moderate baseline)
Control requirement	Supported platform safeguards, such as data execution prevention and address space layout randomization, are enabled to protect memory from unauthorized code execution. Platform limitations and exceptions are documented with compensating measures.
Overlays (additive)	—
NIST CSF 2.0	PR.DS-10
ISO/IEC 27001:2022 Annex A	—
CIS Controls v8.1 Safeguards	10.5
Federal track (inactive overlay)	No SP 800-171 Rev. 3 requirement derives from this control (NIST). No SP 800-171 Rev. 3 requirement number is recorded; relationship to the Rev. 3 requirements is pending confirmation.
Evidence artifacts	Memory protection configuration baseline exports, Technical compliance scan results and documented exceptions
Control owner (role)	Endpoint Engineering Manager
Organization-defined parameters	[ORGANIZATION INPUT REQUIRED] — set values for each 800-53 assignment/selection statement
Implementation status	Documented (draft). Not designed, implemented or evidenced. [CONTROL NOT IMPLEMENTED — ADD TO POA&M]

No published source relationship: ISO 27001. Map by judgment only if an assessor requires it. [ASSESSOR/AUDITOR VALIDATION REQUIRED]

9. Gate 3 Decisions Requested

#	Decision	Recommendation
G3-1	Baseline: NIST SP 800-53B Moderate, all 18 families with Moderate controls, rather than a reduced set	Approve. The Moderate baseline is the documented reference point assessors expect; reducing it would need a rationale per family.

#	Decision	Recommendation
G3-2	PM and PT families handled in Phase 5 (governance) and Phase 7 (privacy overlay) rather than in this library	Approve, with cross-references added when those phases are written.
G3-3	Control-ID convention ORG-<family>-<nnn> using the 800-53 number	Approve.
G3-4	Ownership model: one accountable role per control, from the fixed role list in Section 5	Approve; name individuals per role in Phase 4.
G3-5	Tailoring: no controls tailored out in this issue	Defer tailoring to system SSPs (Phase 6), with rationale per system.

10. Required Records and Evidence

Each control record lists the evidence an assessor would accept. None of that evidence exists yet. Before any control may be reported as implemented, its owner shall produce the listed artifacts and record their location, custodian and retention period. [EVIDENCE REQUIRED]

11. References

- NIST SP 800-53 Rev. 5 (Release 5.2.0) and SP 800-53B — csrc.nist.gov; OSCAL content at github.com/usnistgov/oscal-content
- NIST Cybersecurity Framework 2.0 and CSF 2.0 Reference Tool — nist.gov/cyberframework
- NIST OLIR: SP 800-53 Rev. 5 to ISO/IEC 27001:2022 crosswalk — csrc.nist.gov/projects/olir
- ISO/IEC 27001:2022 — iso.org (Annex A control identifiers only; no standard text reproduced)
- CIS Controls v8.1 and CIS Controls v8.1 Mapping to NIST SP 800-53 Rev. 5 — cisecurity.org (safeguard identifiers only; CC BY-NC-ND 4.0)
- NIST SP 800-171 Rev. 3 — csrc.nist.gov

12. Revision History

Version	Date	Author	Change
0.11	2026-10-27	S. Smith (with Shawn's AI Lab)	First issue: 11 families, 113 controls; all mappings from published sources

13. Approval Record

Role	Name	Date	Decision
CISO / Program Owner	[Insert]	[Insert]	Approve / Approve with changes / Reject
Internal Audit	[Insert]	[Insert]	Approve / Approve with changes / Reject
Control owners (Section 5)	[Insert]	[Insert]	Acknowledge ownership

Learning Mode Note

CISO lens

The library is where budget conversations become concrete. When the Board asks what it costs to meet a customer's ISO requirement, the answer is the subset of ORG controls mapped to those Annex A items that are not yet implemented, not a new project. One library also means one owner per requirement, which is what makes accountability enforceable.

ISSO lens

System security plans inherit from this library: each SSP states, per ORG control, whether it is common, inherited, hybrid or system-specific, and fills in the organization-defined parameters. Assessment in Phase 8 tests the ORG control once and reports the result against every mapped framework.

Challenge questions

- Your ISO column for AC-2 lists Annex A 5.16, 5.18 and 8.2. If an ISO auditor samples 5.18 access-rights reviews, which evidence artifact answers it, and who produces it?
- Several controls have no published CSF or ISO relationship. How will your CSF Target Profile account for controls that do not appear in it?
- IA-2 only satisfies CIS 6.3–6.5 because the Moderate baseline brings in IA-2(1) and IA-2(2). If a system is tailored below Moderate, which CIS safeguards stop being covered?

Common failure

Trusting crosswalks produced from memory. In this build, the AI-drafted mappings were wrong often enough (roughly a third of CSF links and half of ISO links) that an unverified library would have sent auditors to the wrong evidence. Always regenerate mappings from the publisher's crosswalk.

Field use — first 90 days

Walk each family with its owner role: confirm the owner accepts the control, set the organization-defined parameters, and record what evidence exists today. The output is the first real implementation status for every ORG control and the opening POA&M.